SPESIFIKASI SLUG — OCTARINE SANDBOX REPLICA (OSR)

Peta URL kanonik untuk setiap halaman webstore & admin

Versi: 1.1 · **Tanggal:** 30 Oktober 2026 **Basis kode:** `osr-store/server.js` (23.951 B) · `osr-admin/server.js` (26.033 B) · `db/001_schema.sql` **Status:** spesifikasi — sebagian slug sudah hidup, sebagian masih rencana (ditandai eksplisit)

> **Perubahan v1.1:** keranjang & checkout menjadi zona akun — tamu tidak dapat menambah barang atau checkout (`/cart` dan `POST /cart/add|remove|checkout` → 302 login).

---

0. Ringkasan Keputusan

Keputusan	Nilai	Alasan
Bahasa slug	**Inggris**	12 route sudah hidup dengan nama Inggris; mengganti ke Indonesia = 12 titik regresi tanpa manfaat fungsional
Gaya	**kebab-case**, `[a-z0-9-]`	satu-satunya bentuk yang aman untuk path, sitemap, dan log
Kunci entitas	**SKU / reference_no**, bukan slug	slug kosmetik; SKU datang dari ERP dan sudah unik
Slug produk	turunan deterministik dari SKU	wajib agar `make demo` seed 20260918 reproducible
Slug bisa berubah?	**Tidak.** Perubahan = slug baru + baris alias 301	mencegah link mati dan duplikasi indeks
Resolusi	case-insensitive, lalu **301 ke bentuk kanonik**	satu URL sah per halaman

Prinsip tunggal: *slug tidak pernah menjadi sumber kebenaran.* Database tetap mencari lewat `sku` / `reference_no`; slug hanya kunci tampilan yang dipetakan ke kunci asli.

---

1. Aturan Pembentukan Slug

1.1 Normalisasi (7 langkah, urutan wajib)

1. **Unicode NFKD** lalu buang karakter combining — `É` → `E`, `ā` → `a`
2. **Lowercase** — `Sanctum` → `sanctum`
3. **Ganti pemisah** — `+`, `&`, `/`, `_`, `.`, spasi, `|` → `-`
4. **Buang sisanya** — semua di luar `[a-z0-9-]` dihapus
5. **Runtuhkan** — `--` berulang → `-`
6. **Pangkas** — buang `-` di awal/akhir
7. **Potong** ke 80 karakter, lalu ulangi langkah 6 (potongan bisa menyisakan `-` di ujung)

1.2 Batasan

Parameter	Nilai	Konsekuensi bila dilanggar
Panjang	1–80 karakter	>80 dipotong; 0 → pakai `unnamed`
Karakter	`a-z`, `0-9`, `-`	sisanya dibuang, bukan di-encode
`-` berurutan	tidak boleh	diruntuhkan
`-` di ujung	tidak boleh	dipangkas
Case	selalu lowercase	request uppercase → 301
Trailing slash	tidak ada	`/cart/` → 301 `/cart`

1.3 Kata terlarang (reserved)

Slug entitas **tidak boleh** sama dengan segmen statis berikut, karena akan menabrak route:

```
cart  checkout  login  logout  register  account  status  product
search  category  brand  bundle  admin  api  static  assets
healthz  robots.txt  sitemap.xml  favicon.ico  _next
```

Bila hasil slugify menghasilkan kata terlarang, tambahkan akhiran `-p` (produk) atau `-c` (kategori). Contoh: produk bernama "Cart" → `cart-p`.

1.4 Contoh nyata dari fixture ERP

SKU asli	Nama asli	Slug
`M2406-Solace-100ml-A2`	Solace 100ml A2	`m2406-solace-100ml-a2`
`Sanctum+Noctis-20ml-A1`	Sanctum + Noctis 20ml A1	`sanctum-noctis-20ml-a1`
`1MLucky+BloomingBanquet-50ml-A1`	1MLucky + BloomingBanquet 50ml A1	`1mlucky-bloomingbanquet-50ml-a1`
`M1058-SagewoodSeaSalty-20ml-A1`	WUD SAGA - Parfum Garansi Tahan Lama	`m1058-sagewoodseasalty-20ml-a1`
`EAU DE PARFUM` (kategori)	—	`eau-de-parfum`
`MEN` (brand)	—	`men`

Catatan penting: `Sanctum+Noctis-20ml-A1` dan `Sanctum-Noctis-20ml-A1` menghasilkan slug **identik**. Tabrakan ini nyata, bukan teoretis — karena `+` dan `-` sama-sama jadi `-`. Penanganannya di §1.5.

1.5 Tabrakan slug (collision)

```
for tiap SKU diurutkan ORDER BY sku:
    base = slugify(sku)
    bila base belum dipakai → slug = base
    bila sudah dipakai      → slug = base + "-2", lalu "-3", dst.
```

Urutan `ORDER BY sku` menjamin hasil **deterministik lintas run**. Tanpa urutan eksplisit, Postgres bebas mengembalikan baris dalam urutan apa pun dan slug bisa berpindah antar-run — ini akan mematahkan uji determinisme `tools/check_determinism.py`.

---

2. Peta Slug — Storefront (Publik)

Slug	Halaman	Auth	Status
`/`	Beranda: katalog, pencarian; tombol tambah hanya untuk sesi aktif	publik	**ADA**
`/product/{slug}`	Detail produk + komposisi BOM untuk bundle	publik	**ADA** (kunci masih SKU mentah)
`/search?q={kata}`	Hasil pencarian; `q` kosong → 302 `/`	publik	RENCANA
`/category/{slug}`	Daftar per kategori ERP (`eau-de-parfum`)	publik	RENCANA
`/brand/{slug}`	Daftar per brand ERP (`men` , `unisex`)	publik	RENCANA
`/bundle`	Hanya produk `is_bundle = true`	publik	RENCANA
`/cart`	Keranjang; tamu → 302 `/login?next=/cart&reason=cart`	**sesi**	**ADA**
`/login`	Form masuk; `?next=` divalidasi internal-only	publik	**ADA**
`/register`	Form daftar; peran dipaksa `customer`	publik	**ADA**
`/logout`	POST saja; GET → 405	sesi	**ADA**
`/account`	Profil + riwayat pesanan + tautan lacak	sesi	**ADA**
`/account/orders`	Daftar pesanan lengkap dengan filter status	sesi	RENCANA
`/account/orders/{ref}`	Detail satu pesanan	sesi (milik sendiri)	RENCANA
`/status/{ref}`	Riwayat status; pelanggan lain → 403	sesi	**ADA**
`/checkout/success/{ref}`	Konfirmasi + nomor lacak	sesi	RENCANA
`/checkout/failed`	Checkout ditolak (stok habis / kuota bundle)	sesi	RENCANA

Aksi tulis (bukan halaman, tidak punya slug):

Method	Path	Auth	Keterangan
POST	`/cart/add`	**sesi**	tambah item; tamu → 302 login (barang **tidak** ditambahkan)
POST	`/cart/remove`	**sesi**	hapus item
POST	`/checkout`	**sesi**	buat order → Jalur B; tamu ditolak, core juga 401
POST	`/login` , `/register` , `/logout`	publik	autentikasi

Aturan: **setiap aksi tulis hanya menerima POST.** GET ke path aksi → 405 dengan `Allow: POST`, bukan 404, supaya salah-method tidak tersamar sebagai halaman hilang.

---

3. Peta Slug — Admin

Slug	Halaman	Izin wajib	Status
`/login`	Masuk staf	—	**ADA**

Slug	Halaman	Izin wajib	Status
`/logout`	POST; cabut sesi	sesi	**ADA**
`/`	Dashboard: metrik dua jalur + DPMO	`admin.dashboard.view`	**ADA**
`/webhook-events`	Cermin event webhook, filter `?event=`	`admin.events.view`	**ADA**
`/anomalies`	Panel anomali	`admin.anomalies.view`	**ADA**
`/orders`	Seluruh order lintas kanal	`admin.orders.view`	**ADA**
`/orders/{ref}`	Detail order + riwayat status	`admin.orders.view`	RENCANA
`/baseline`	Gate reproduksi angka paper	`admin.baseline.view`	**ADA**
`/users`	Daftar akun, filter `?q=`	`admin.users.view`	**ADA**
`/users/{id}`	Detail akun + jejak peran	`admin.users.view`	RENCANA
`/auth-events`	Jejak autentikasi append-only	`admin.users.view`	**ADA**

Aksi tulis admin:

Method	Path	Izin
POST	`/action/sync`	`admin.action.sync`
POST	`/action/reconcile`	`admin.action.reconcile`
POST	`/action/replay`	`admin.action.replay`
POST	`/users/create`	`admin.users.manage`
POST	`/users/role`	`admin.users.manage`
POST	`/users/status`	`admin.users.manage`

Catatan keamanan: `/action/{what}` mengambil nama aksi dari segmen URL terakhir. Segmen itu **wajib** dicocokkan ke daftar putih (`sync`, `reconcile`, `replay`) sebelum dipakai — jangan pernah meneruskan segmen mentah ke pemanggilan fungsi dinamis.

---

4. Slug Entitas Dinamis

4.1 Produk

```
/product/{slug}          contoh: /product/sanctum-noctis-20ml-a1
```

- `slug` = `slugify(sku)` + penanganan tabrakan §1.5
- Disimpan di kolom baru `erpsim.variant.slug` dengan `UNIQUE`
- **Immutabel**: setelah dibuat, tidak pernah ditulis ulang walau nama produk berubah di ERP
- Resolusi: `SELECT sku FROM erpsim.variant WHERE slug = $1`
- SKU mentah di path (`/product/Sanctum%2BNoctis-20ml-A1`) → **301** ke slug kanonik

Kenapa bukan nama produk sebagai slug: nama ERP panjang dan tidak stabil (`"WUD SAGA - Parfum Garansi Tahan Lama ..."` terpotong di 80 karakter), dan dua produk berbeda bisa punya nama sama. SKU stabil; nama tidak.

4.2 Kategori & Brand

```
/category/{slug}          contoh: /category/eau-de-parfum
/brand/{slug}             contoh: /brand/men
```

Diturunkan dari field `category` dan `brand` pada payload ERP (`GET /api/webhooks/catalog`). Tidak disimpan di tabel sendiri pada rilis pertama — cukup `DISTINCT` dari cache katalog. Bila jumlahnya melewati ~200, baru dipromosikan ke tabel `osr_taxonomy`.

4.3 Order

```
/status/{ref}             contoh: /status/ord-webstore-verify-1793292053916
/account/orders/{ref}
/orders/{ref}             (admin)
```

- `ref` = `lowercase(reference_no)` dari ERP — mis. `ORD-WEBSTORE-VERIFY-1793292053916` → `ord-webstore-verify-1793292053916`
- Pencarian memakai `LOWER(reference_no) = $1`; bentuk uppercase di URL → **301** ke lowercase
- `reference_no` adalah kunci bisnis dari ERP dan tidak pernah dibuat ulang oleh OSR

4.4 Akun

```
/users/{id}               contoh: /users/7
```

ID numerik, bukan slug. Nama pengguna bisa berubah dan bisa kembar; ID tidak. Tidak ada alasan kosmetik untuk slug di sini.

---

5. Perilaku HTTP (redirect & status)

Situasi	Respons	Header
Slug benar	200	—
Slug ada di alias lama	**301** ke slug kanonik	`Location` + `Cache-Control: public, max-age=86400`
Case salah (`/Cart`)	**301** ke lowercase	—
Trailing slash (`/cart/`)	**301** ke tanpa slash	—
SKU mentah di `/product/`	**301** ke slug	—
Slug tidak dikenal	**404** + saran 3 produk terdekat	—
Method salah pada aksi	**405**	`Allow: POST`
Belum masuk pada halaman sesi	**302** ke `/login?next={path}`	`next` hanya boleh path internal
Izin kurang	**403** halaman "Tidak berwenang"	sebut `perm_code` yang dibutuhkan
Resource ada tapi bukan milik pemanggil	**403**, bukan 404	404 akan menyembunyikan keberadaan data, tapi menyulitkan dukungan

Aturan `?next=`: hanya menerima nilai yang diawali `/` dan **tidak** diawali `//`. Ini sudah diimplementasikan di kedua server (`safeNext`) dan harus dipertahankan — tanpa itu, `?next=//evil.tld` menjadi open redirect.

Query string dipertahankan saat redirect. `/Cart?q=solace` → `/cart?q=solace`.

6. Sitemap, robots, dan Kanal Non-Halaman

Path	Isi
`/sitemap.xml`	Hanya halaman publik: `/`, semua `/product/{slug}`, `/category/*`, `/brand/*`, `/bundle`. **Tidak** memuat `/cart`, `/account`, `/status`, `/login`, `/register`
`/robots.txt`	`Allow: /` · `Disallow: /cart`, `/account`, `/status`, `/login`, `/register`, `/checkout` · `Sitemap: {base}/sitemap.xml`
`/healthz`	`200 {"ok":true}` — bukan halaman, tidak diindeks
`/favicon.ico`	aset statis

Sitemap dibangun dari query yang sama dengan katalog, sehingga produk yang stoknya nol tetap muncul (halaman tetap valid, hanya tombol beli dinonaktifkan). Ini mencegah fluktuasi indeks saat stok naik-turun.

7. Implementasi — Berkas yang Berubah

7.1 Fungsi `slugify` (Python + JS, hasil wajib identik)

```python
# osr-core/slug.py
import re, unicodedata

RESERVED = {"cart","checkout","login","logout","register","account","status",
            "product","search","category","brand","bundle","admin","api",
            "static","assets","healthz"}

def slugify(text: str, suffix_if_reserved: str = "") -> str:
    s = unicodedata.normalize("NFKD", str(text))
    s = "".join(c for c in s if not unicodedata.combining(c))
    s = s.lower()
    s = re.sub(r"[+&/_.\s|]+", "-", s)      # pemisah -> '-'
    s = re.sub(r"[^a-z0-9-]", "", s)        # buang sisanya
    s = re.sub(r"-{2,}", "-", s).strip("-")
    s = s[:80].rstrip("-") or "unnamed"
    if s in RESERVED and suffix_if_reserved:
        s = f"{s}-{suffix_if_reserved}"
    return s
```

```javascript
// osr-store/slug.js  — cermin 1:1 dari versi Python
const RESERVED = new Set(["cart","checkout","login","logout","register","account",
  "status","product","search","category","brand","bundle","admin","api",
  "static","assets","healthz"]);

function slugify(text, suffixIfReserved = "") {
  let s = String(text).normalize("NFKD").replace(/[\u0300-\u036f]/g, "").toLowerCase();
  s = s.replace(/[+&/_.\s|]+/g, "-").replace(/[^a-z0-9-]/g, "");
  s = s.replace(/-{2,}/g, "-").replace(/^-+|-+$/g, "");
  s = s.slice(0, 80).replace(/-+$/g, "") || "unnamed";
  if (RESERVED.has(s) && suffixIfReserved) s = `${s}-${suffixIfReserved}`;
  return s;
}
```

Dua implementasi ini **harus** menghasilkan output identik. Uji paritas wajib ada di `tools/`: baca 3.727 SKU dari fixture, bandingkan hash gabungan kedua implementasi. Bila berbeda satu karakter, link yang dibuat server dan link yang dibuat seeder akan menunjuk halaman berbeda.

7.2 Migrasi database — `db/003_slug.sql`

```
ALTER TABLE erpsim.variant ADD COLUMN IF NOT EXISTS slug TEXT;

CREATE UNIQUE INDEX IF NOT EXISTS ux_variant_slug
  ON erpsim.variant (slug) WHERE slug IS NOT NULL;

CREATE TABLE IF NOT EXISTS osr_slug_alias (
  scope       TEXT NOT NULL,              -- 'product' | 'category' | 'brand'
  old_slug    TEXT NOT NULL,
  target_slug TEXT NOT NULL,
  created_at  TIMESTAMPTZ NOT NULL DEFAULT now(),
  PRIMARY KEY (scope, old_slug)
);
```

Kolom `slug` sengaja **nullable**: baris yang baru masuk dari ERP boleh kosong sesaat, lalu diisi oleh `catalog_sync`. Unique index parsial `WHERE slug IS NOT NULL` mengizinkan banyak baris kosong tanpa melanggar konstrain.

7.3 Titik perubahan di kode

Berkas	Perubahan
`osr-store/server.js`	route `/product/{slug}` → resolusi slug→sku lewat core; tambah `/search`, `/category/*`, `/brand/*`, `/bundle`
`osr-store/slug.js`	**BARU** — cermin slugify
`osr-core/app.py`	endpoint `GET /api/catalog/slug/{slug}`; `slug` disertakan di setiap item katalog
`osr-core/catalog_sync.py`	isi `variant.slug` setelah upsert, urut `ORDER BY sku`
`osr-admin/server.js`	tambah `/orders/{ref}`, `/users/{id}`
`tools/build_fixtures.py`	sertakan `slug` di fixture agar seed reproducible
`db/003_slug.sql`	**BARU** — migrasi

7.4 Pemetaan route lama → baru

Route lama	Route baru	Penanganan
`/product/{sku}`	`/product/{slug}`	SKU → **301** slug
`/status/{REF}`	`/status/{ref}`	uppercase → **301** lowercase
`/` dengan `?q=`	`/search?q=`	`/` tanpa `q` tetap beranda; `/search` tanpa `q` → **302** `/`

Semua route lama tetap **berfungsi** lewat 301. Tidak ada link mati saat rilis.

---

8. Uji Penerimaan

```
B=http://localhost:3000

# 1. slug produk kanonik
curl -s -o /dev/null -w '%{http_code}\n' $B/product/sanctum-noctis-20ml-a1        # 200

# 2. SKU mentah -> 301 ke slug
curl -s -o /dev/null -w '%{http_code} %{redirect_url}\n' \
  $B/product/Sanctum%2BNoctis-20ml-A1                                            # 301 .../sanctum-noctis-20ml-a1

# 3. case & trailing slash
curl -s -o /dev/null -w '%{http_code}\n' $B/Cart                                  # 301
curl -s -o /dev/null -w '%{http_code}\n' $B/cart/                                 # 301

# 4. slug tak dikenal -> 404, bukan 500
curl -s -o /dev/null -w '%{http_code}\n' $B/product/tidak-ada-produk-ini          # 404

# 5. method salah -> 405 + Allow
curl -s -X GET -D- -o /dev/null $B/checkout | grep -i '^allow'                    # Allow: POST

# 6. next= tidak bisa keluar domain
curl -s -o /dev/null -w '%{redirect_url}\n' "$B/login?next=//evil.tld"            # /login (bukan evil.tld)

# 7. sitemap tidak memuat halaman sesi
curl -s $B/sitemap.xml | grep -c -E '/cart|/account|/status|/login'               # 0

# 8. paritas slugify Python vs JS
python3 tools/slug_parity.py                                                      # 3727 SKU, 0 beda
```

No	Uji	Kriteria lulus
1	Slug kanonik	200
2	SKU mentah	301 ke slug
3	Case / trailing slash	301, satu lompatan saja
4	Slug tak dikenal	404
5	Method salah	405 + `Allow: POST`
6	Open redirect	ditolak
7	Sitemap bersih	0 halaman sesi
8	Paritas Python↔JS	0 beda dari 3.727 SKU

---

9. Dampak ke Dokumen Lain

Dokumen	Bagian	Perubahan
`BLUEPRINT_SIMULASI.md`	§7 Struktur Repositori	tambah `osr-store/slug.js`, `osr-core/slug.py`
`BLUEPRINT_SIMULASI.md`	§8 Model Data	tambah kolom `variant.slug`, tabel `osr_slug_alias`
`BLUEPRINT_SIMULASI.md`	§9 Kontrak API	item katalog menyertakan `slug`
`DOKUMEN_RBAC.md`	tabel route	`/product/{sku}` → `/product/{slug}`
`LAPORAN_QA_v1.0.1`	matriks uji	tambah 8 uji slug (§8)

---

10. Yang Sengaja Tidak Dilakukan

1. **Tidak memakai nama produk sebagai slug** — tidak stabil, bisa kembar, terpotong 80 karakter.
2. **Tidak membuat slug untuk aksi tulis** — `POST /checkout` bukan halaman; memberinya slug akan menyesatkan crawler.
3. **Tidak memakai slug sebagai primary key** — satu perubahan nama di ERP tidak boleh merusak referensi order historis.
4. **Tidak melakukan transliterasi ke bahasa Indonesia** — `product` tidak jadi `produk`; biaya regresi 12 route lebih besar dari manfaat kosmetik.
5. **Tidak mengizinkan slug berubah otomatis** — perubahan slug hanya lewat migrasi eksplisit yang menulis baris alias.

Dokumen ini turunan dari BLUEPRINT_SIMULASI v0.8.1 §7 dan §9, serta route aktual `osr-store/server.js` dan `osr-admin/server.js` per 30 Oktober 2026.